420-1C2-DW · Threats and Risks · Class 2

Identifying Information Assets (Part 1)

Topic 2 — what Kalmia owns, what runs on it, what matters most, and a first authorized scan

Friday, October 23, 2026 · 6:00 – 10:00 pm · Online

AEC Cybersecurity: Prevention and Intervention (LEA.D8)

Competency EZ02 — performance criteria 1.1 and 1.2

Abbreviations: **AEC** (Attestation d'études collégiales, a Québec college-level professional program)

Asen Grozdanov
Cyber.SoHo Educational Hub

Tonight: four lessons in sixty minutes

1 Hardware inventory and associated permissions

0:00 – 0:16

You can: record a device with the fields of **CIS** Safeguard 1.1, reconcile four sources, and say who can administer each device.

2 Software inventory, licences and associated permissions

0:16 – 0:31

You can: record what runs where, with its version, support status and licence, and find the software that runs with too much privilege.

3 Asset classification, ownership and criticality

0:31 – 0:45

You can: label information, compute the security category, name the owner and the custodian, and rank assets by criticality.

4 Hands-on: building an asset inventory with a template and Nmap

0:45 – 1:00

You can: scan the lab replica inside a written authorization and turn the results into rows of the Lab 1 template.

Abbreviations: **CIS** (Center for Internet Security) · **Nmap** (Network Mapper)

Legal and ethical notice — read before any lab

- Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved.
- Use only in an isolated, authorized lab environment, against the targets an exercise designates.
- Unauthorized access may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1), 184).
- Tonight's scan: only 192.168.10.0/24 in the lab replica, with the written authorization (7.6, Annex D).
- **Nmap** (Network Mapper) is a dual-use tool (6.5): lawful use only, never your home, employer or college network.
- No cracked or unlicensed software in any lab (6.6); fictional data only (6.7, 7.9).
- Inventories and scan results are confidential findings (7.5).
- Check every link before clicking — VirusTotal, Google Safe Browsing (14.2, Annex C).
- Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0 (link in the module).

§

Section 7.6 — a scan is an intrusive act, not an observation

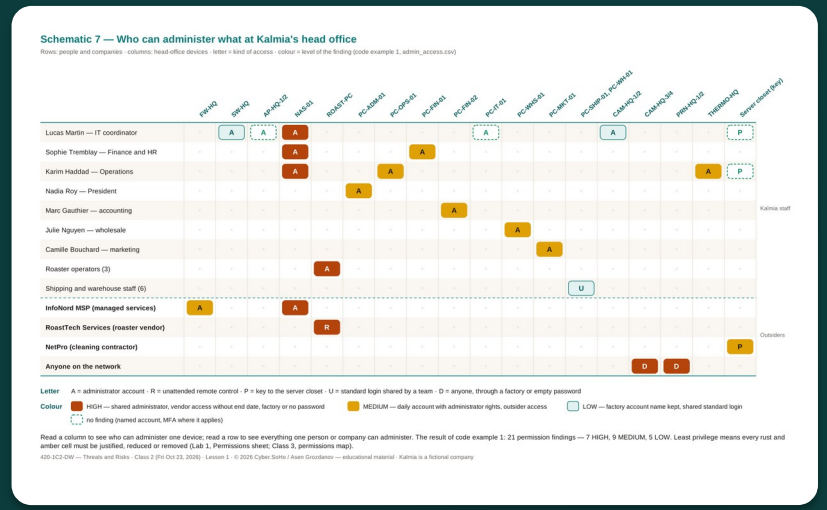
Annex D	Written authorization: range, exclusions, dates, contact
6.5	Dual-use tools: lawful use only
6.6	No cracked or unlicensed software
7.5	Inventories and scans stay confidential
Annex C	Check every link before you click

1

Lesson 1 · 0:00 – 0:16

Hardware inventory and associated permissions

- Why the inventory comes first
- One record per device — **CIS** Safeguard 1.1
- Four sources, four reconciliation states
- Life cycle and disposal
- Who can administer what



Schematic 7 — Who can administer what at Kalmia's head office

Abbreviations: **CIS** (Center for Internet Security)

Why the hardware inventory comes first

- Every risk concerns an asset: without an asset, no risk statement
- “How many computers?” → a number, a list and a network: three different answers
- Devices missing from one count are the ones nobody updates or protects
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 · ID.AM-01: inventories of hardware are maintained
- **CIS** (Center for Internet Security) Controls v8.1 · Control 1: Inventory and Control of Enterprise Assets
- Cyber Centre ITSM.10.004: fewer rogue, lost or obsolete devices; faster incident response
- EZ02 · criterion 1.1: the hardware inventory and its associated permissions

1st

CIS Control 1 — enterprise assets

ID.AM-01

NIST CSF 2.0 — hardware inventories

1.1

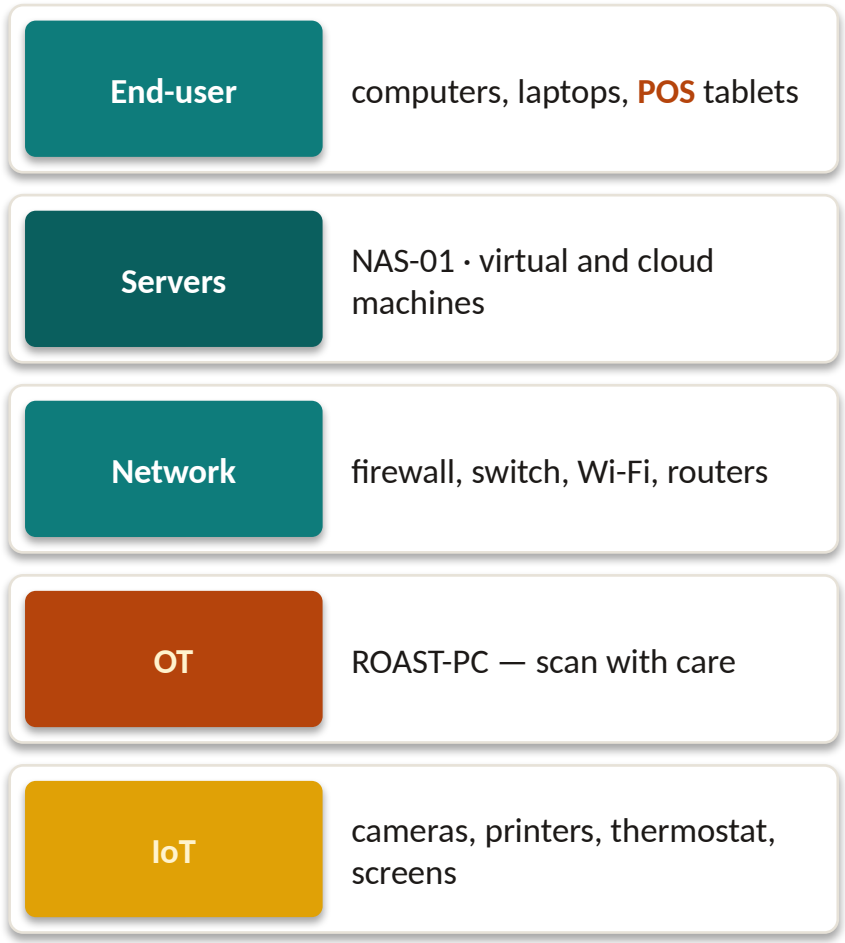
EZ02 — first performance criterion

3

answers to one question: count, list, network

What counts as a hardware asset — the families at Kalmia

- Any physical or virtual device that stores, processes or transmits information
- End-user devices — 12 Windows 11 computers, 2 sales laptops (Windows 10), 9 **POS** (point of sale) tablets
- Servers and storage — NAS-01 and its **USB** (Universal Serial Bus) backup disk
- Network devices — FW-HQ, SW-HQ, AP-HQ-1 and AP-HQ-2, three café routers
- Operational technology (**OT**) — ROAST-PC, the roaster's control computer
- Connected devices — 7 cameras, 3 printers, the thermostat, menu boards, card readers
- Virtual and cloud machines count, even if nobody can touch them
- Personal phones on the staff Wi-Fi: not Kalmia's, but recorded as present



Abbreviations: **IoT** (Internet of Things)

One record per device — CIS Safeguard 1.1 (1/2)

Field	What it means	NAS-01
Asset tag	Unique label stuck on the device; never changed, never reused	KAL-0005
Hostname	The name the device uses on the network	NAS-01
MAC (Media Access Control) address	48-bit identifier of the network interface; first 24 bits (**OUI** (Organizationally Unique Identifier)) = manufacturer	00:11:32:6B:2E:91 (Synology)
IP (Internet Protocol) address	Static (fixed by hand) or leased by a **DHCP** (Dynamic Host Configuration Protocol) server	192.168.10.10, static
Type, make, model, serial	What the device is, exactly	Synology DS920+, 2160PDN7731
Owner	The person accountable for the device and its risks	Lucas Martin

CIS Safeguard 1.1 requires six: network address if static · hardware address · machine name · owner · department · approved to connect

Abbreviations: **CIS** (Center for Internet Security)

One record per device — CIS Safeguard 1.1 (2/2)

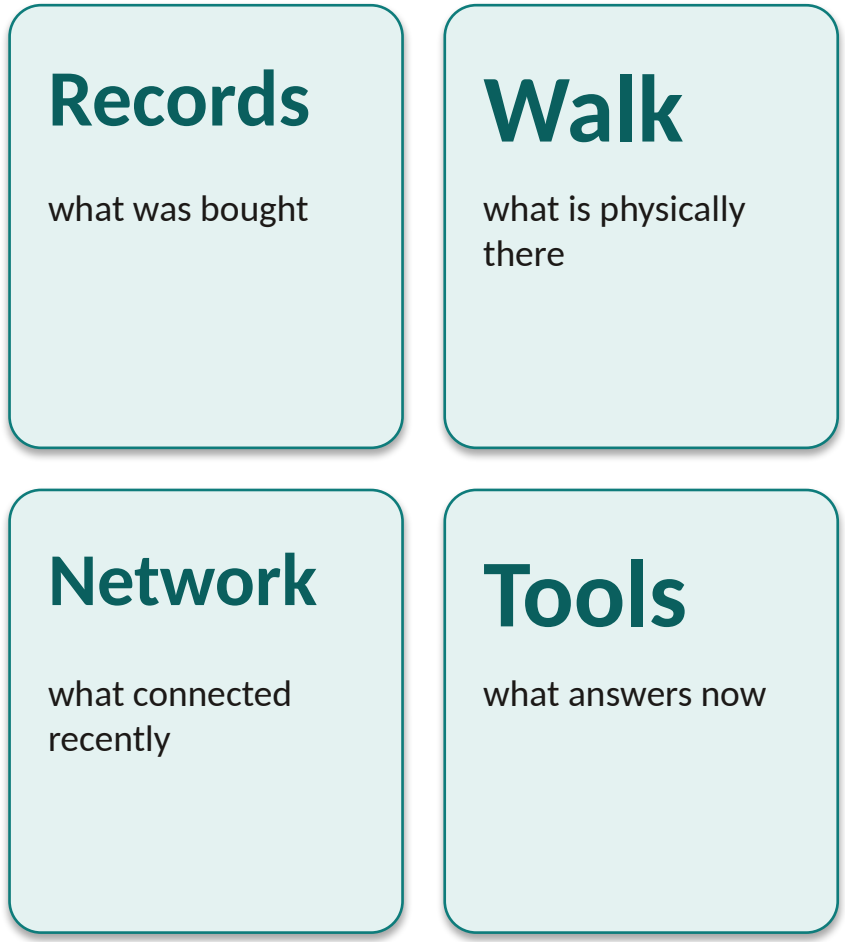
Field	What it means	NAS-01
User or custodian	Who uses it or looks after it every day	Lucas Martin
Department, location	Where it belongs and where it physically is	IT (information technology) · server closet
Approved to connect	Yes or no — a device not approved has no place on the network	Yes
OS (operating system) or firmware, version	What runs on it — needed in Topic 4 to find obsolete versions	DSM (DiskStation Manager, the operating system of Synology storage) 7.2
Status, last seen	In stock, in use, in repair, retired; last sighting on the network	In use · 2026-10-23

The MAC address is the key; the IP address changes with DHCP
A randomized (private) MAC address has no manufacturer prefix: the device cannot be identified from its address alone

Abbreviations: **CIS** (Center for Internet Security) · **DHCP** (Dynamic Host Configuration Protocol) · **IP** (Internet Protocol) · **MAC** (Media Access Control)

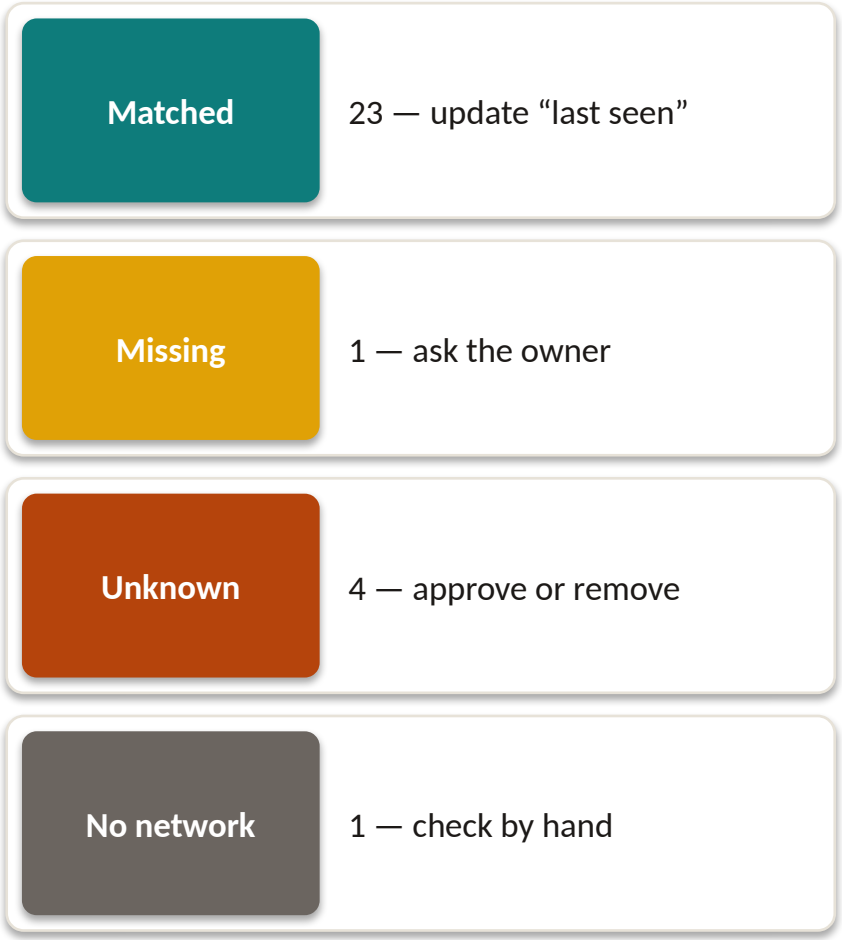
Four sources — no single source sees everything

- Records — invoices, asset register, contracts: what was bought
- Physical verification — walk the site: the disk in the closet, the laptop in a drawer
- Network records — **DHCP** (Dynamic Host Configuration Protocol) log, **ARP** (Address Resolution Protocol) table, switch **MAC** (Media Access Control) table: what connected recently (**CIS** (Center for Internet Security) 1.4)
- Discovery tools — active scanner such as **Nmap** (**CIS** 1.3), passive listening (**CIS** 1.5)
  - management agents on computers and phones (endpoint management, **MDM** (mobile device management))
- Comparing the sources is called reconciliation



Reconciliation — four states, one decision for each

- Matched — recorded and seen recently → update “last seen”
- Missing — recorded, not seen for too long (Kalmia: 30 days) → ask the owner
- Unknown — seen, never recorded → identify; remove, block or quarantine — or approve and record it
- Not network-visible — no network interface → check it by hand
- **CIS** (Center for Internet Security) Safeguard 1.2: a weekly process for unauthorized devices — remove, deny remote connection, quarantine
- An unknown device is not automatically malicious — but never ignored



The life cycle — from purchase to sanitization

- Five phases (Cyber Centre, ITSM.10.004):
  - planning · procurement and acquisition · deployment · operation and maintenance · retirement and disposal
- Deployment: asset tag, owner and secure configuration before the first connection
- Disposal: the storage is sanitized — no information leaves with the device
- Reference: **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-88 Rev. 2, Guidelines for Media Sanitization (September 2025)
- The inventory follows each device through every phase



Associated permissions — who can do what with each device

- Permission = an identity + an action + a resource
- Physical access — touch, open, plug something in
- Local administration — install software, change settings
- Remote administration — web page, **SSH** (Secure Shell), remote desktop
- Ordinary use — log in and work
- Least privilege: only the rights the job needs, only as long as it needs them
- Accountability: every action traced to one person — impossible with a shared account
- Factory user names and passwords are changed before a device enters service



Abbreviations: **RDP** (Remote Desktop Protocol)

Factory passwords at scale — the Mirai botnet (2016)

- Mirai tried a built-in list of about sixty factory user names and passwords
- Targets: cameras and video recorders accepting Telnet connections from the Internet
- Hundreds of thousands of devices taken over
- Used for some of the largest denial-of-service attacks of the time
- **US-CERT** (United States Computer Emergency Readiness Team) alert TA16-288A, now on the **CISA** (Cybersecurity and Infrastructure Security Agency) website — first remedy: change the default passwords
- For each device, the inventory records: administrator accounts, who knows each password, **MFA** (multi-factor authentication), outside access and until when
- Tomorrow (Class 3): this list becomes Kalmia's permissions map

~60

factory user names and passwords tried

23/tcp

Telnet open to the Internet

2016

record-size denial-of-service attacks

TA16-288A

US-CERT alert, October 2016

Real-life example 1 — reconciling the hardware register

Result	Devices	Next action
Matched — 23	Network devices, NAS-01, ROAST-PC, 10 computers, 4 cameras, 2 printers, thermostat	Update “last seen”
Missing — 1	SALES-LT2 (Windows 10), last seen 42 days ago	Ask Karim Haddad: on the road, lost, stolen?
Not network-visible — 1	BKP-USB-01, the **USB** (Universal Serial Bus) disk of NAS-01	Physical check every month
Unknown — 4	Raspberry Pi (.150), TP-Link extender (.151), two phones (.160, .161)	Identify; approve and record, or remove
Permissions HIGH — 7	Shared admin on NAS-01 and ROAST-PC, vendor access without end date, factory or empty passwords	Risk factors for Lab 3
MEDIUM — 9 · LOW — 5	Daily accounts with admin rights, outsider access, factory account names	Permissions map (Class 3)

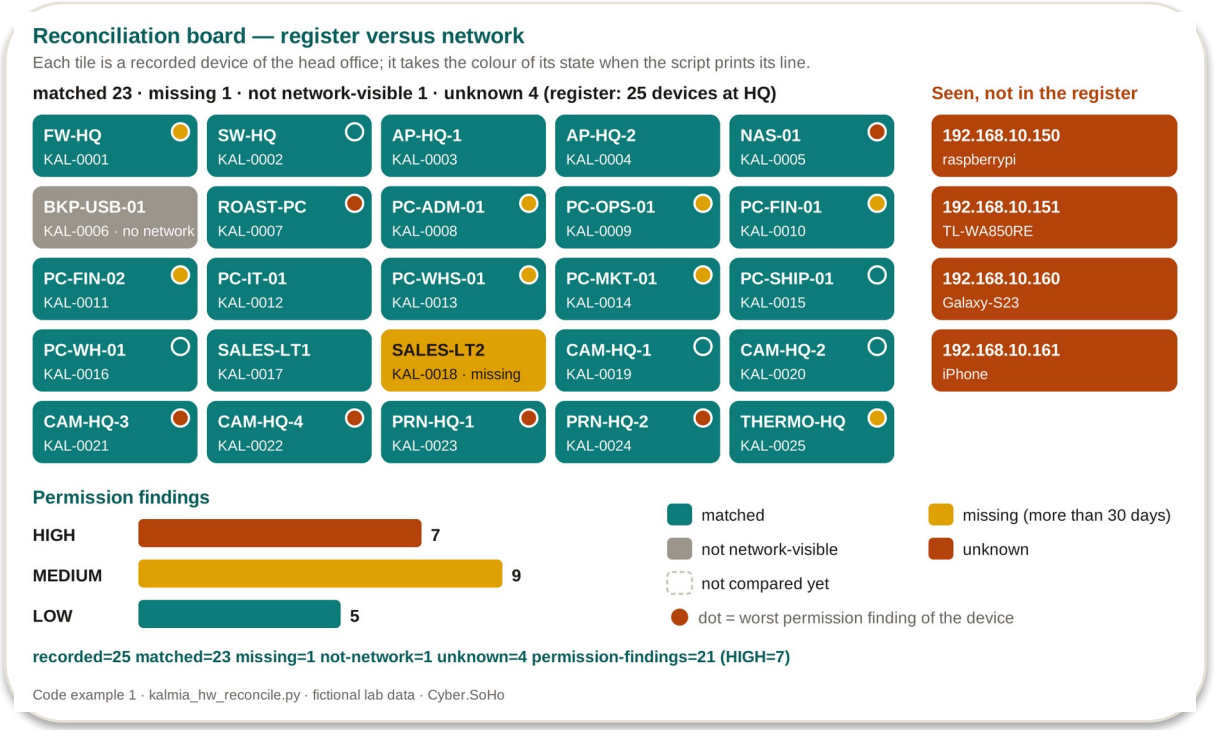
Compare sources
register × network × walk-through

Classify differences
matched · missing · unknown · not visible

Decide and record
one action per device, written down

Code example 1 — kalmia_hw_reconcile.py (Python)

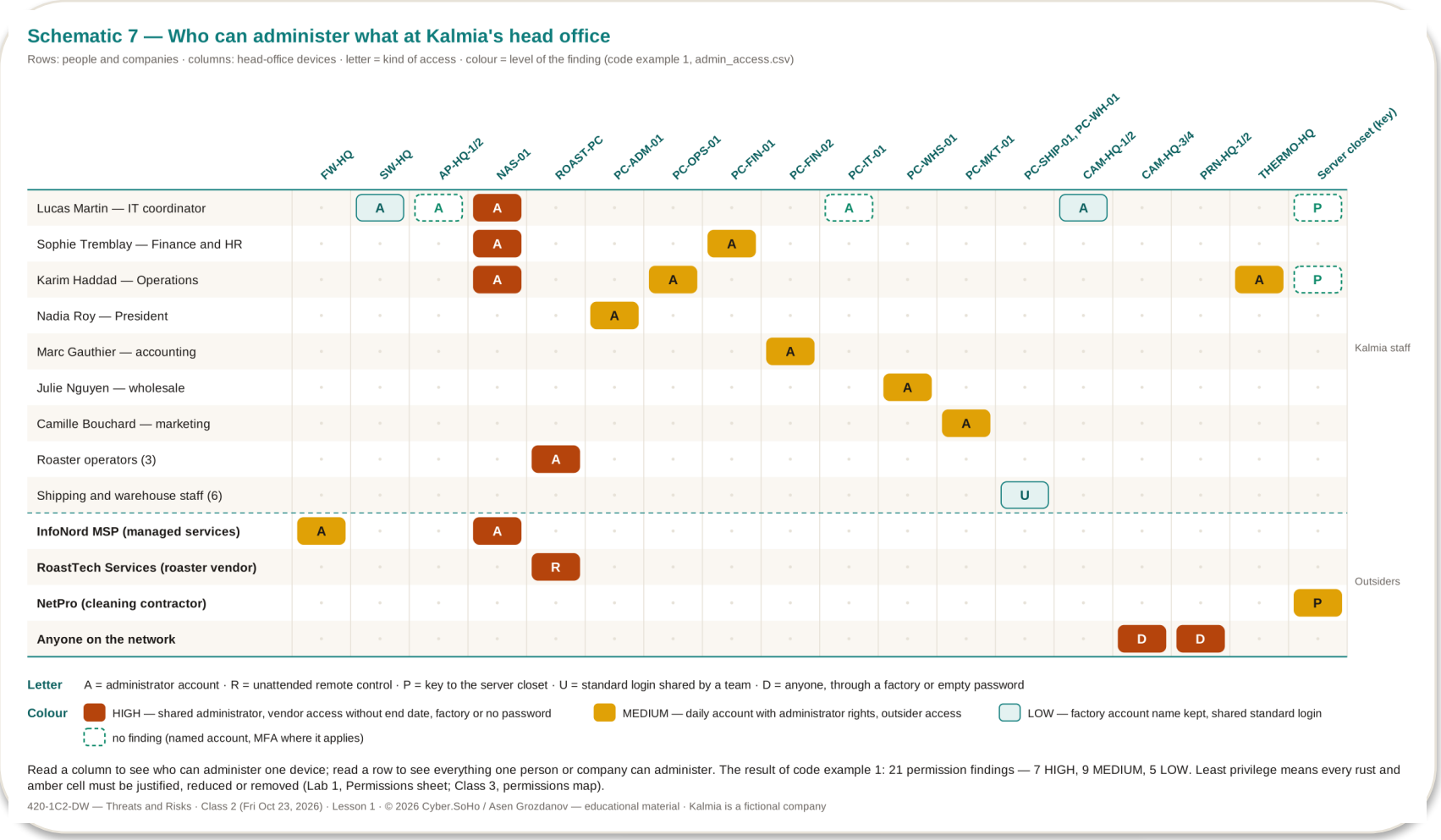
- Reads the register, the network sightings and the admin accounts
- Normalizes every **MAC** (Media Access Control) address, then matches by **MAC**
- Prints MATCH, MISSING (> 30 days), NOT-NETWORK and UNKNOWN
- Reviews every account: HIGH, MEDIUM or LOW, with the reason
- Writes hw_reconciled.csv and permission_findings.csv → Lab 1
- In the module: Start, Pause, Step, Next output, Restart — and the execution window



Final state of the visualization in the code runner of the lecture module — Start, Pause, Step, Next output, Restart

```
$ python kalmia_hw_reconcile.py hw_inventory.csv network_sightings.csv admin_access.csv
```

Schematic 7 — Who can administer what at Kalmia's head office

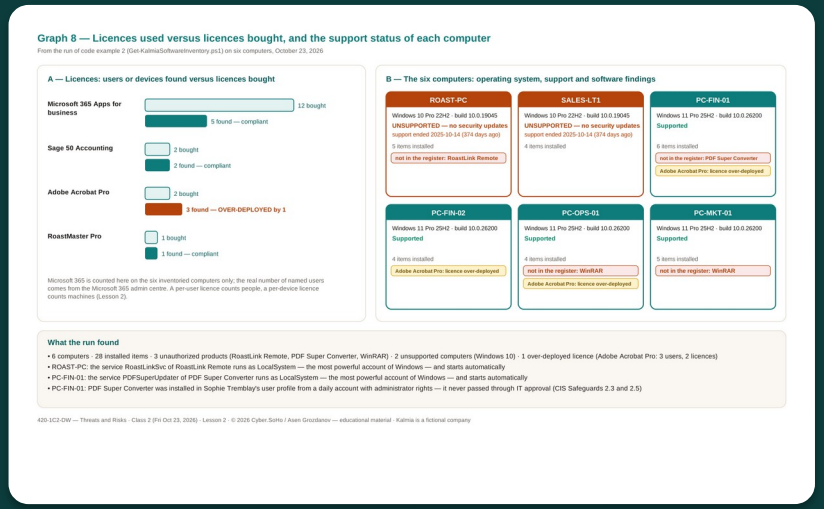


2

Lesson 2 · 0:16 – 0:31

Software inventory, licences and associated permissions

- Why software needs its own inventory
- The record and the end-of-support date
- Licences and their metrics
- The rights programs run with
- Collecting the data



Graph 8 — Licences used versus licences bought, and the support status of each computer

Why software needs its own inventory

- Attacks exploit programs and their rights far more often than hardware
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 · ID.AM-02: inventories of software, services and systems are maintained
- **CIS** (Center for Internet Security) Control 2: only authorized software is installed and can run
- EZ02 · criterion 1.2: the software inventory and its associated permissions
- Log4Shell, December 2021 (CVE-2021-44228): a flaw in a small logging component
  - **CISA** (Cybersecurity and Infrastructure Security Agency)'s first step for everyone: find which programs contain it
- Knowing what runs = checking quickly; not knowing = searching computer by computer

ID.AM-02

software, services and systems

Control 2

CIS — software assets

Log4Shell

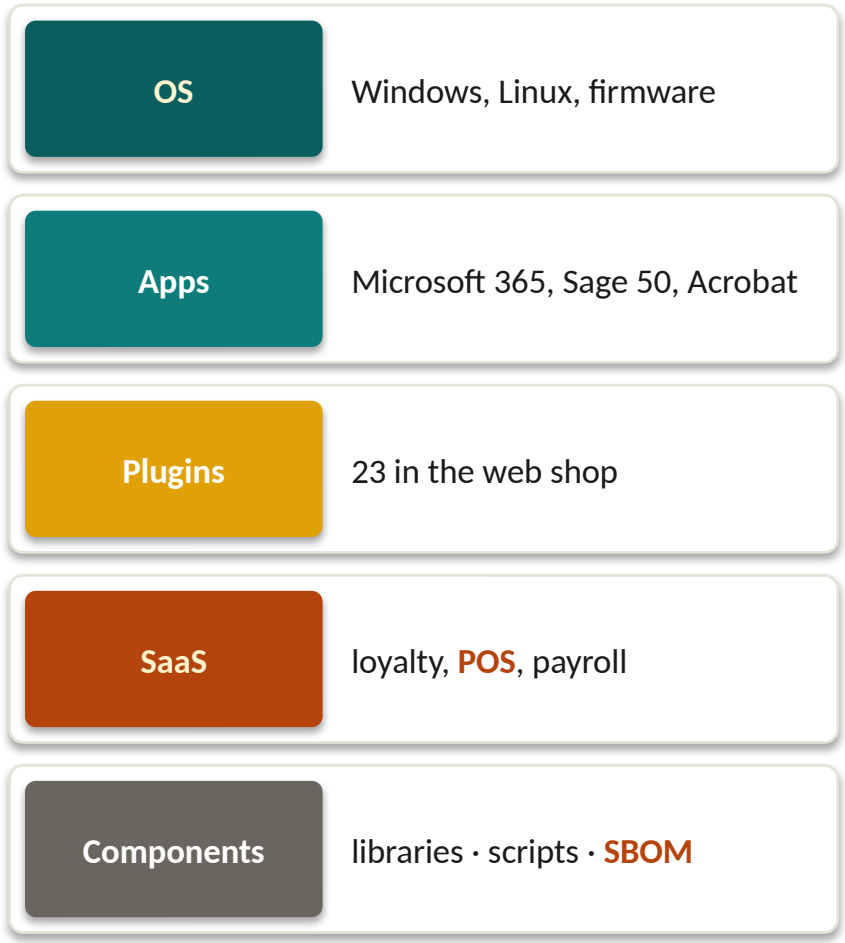
CVE-2021-44228 · December 2021

1.2

EZ02 — second criterion

What counts as software — five kinds

- Operating systems — Windows 10 and 11, the Linux of NAS-01, the firmware of devices
- Applications — Microsoft 365, Sage 50, Adobe Acrobat, the roasting software, browsers
- Extensions and plugins — the 23 plugins of the web shop, each with its own version
- Cloud services (**SaaS** (software as a service)) — loyalty, **POS** (point of sale), payroll: accounts, data and contracts (ID.AM-04)
- Components and scripts — libraries inside programs, administrators' scripts
- **SBOM** (software bill of materials) — the list of components inside one product (**CISA** (Cybersecurity and Infrastructure Security Agency) publishes its minimum elements)



Abbreviations: **OS** (operating system)

The software record — CIS Safeguard 2.1

- Required for each item: title, publisher, initial install or use date, business purpose
- Where applicable: **URL** (Uniform Resource Locator, the address of a web page), app store, version, deployment mechanism, decommission date, number of licences
- Reviewed and updated at least twice a year
- Three columns added for risk analysis:
  - the computer it is on
  - authorized or not (present in the approved list)
  - supported or not by its publisher

4
required fields

6
fields where applicable

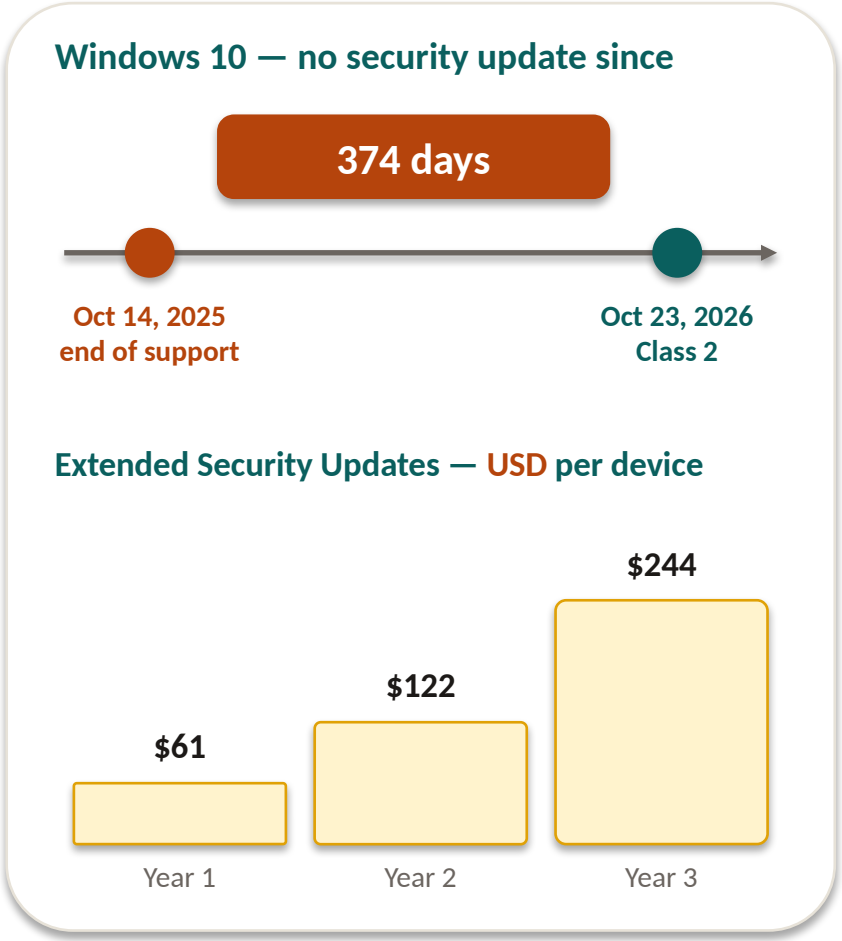
2 ×
reviews per year

+3
risk columns: host, authorized, supported

Abbreviations: **CIS** (Center for Internet Security)

Supported or not — the end-of-support date

- End of support (end of life): no more security updates after that date
- Every flaw found afterwards stays open forever
- **CIS** (Center for Internet Security) 2.2: only supported software is authorized — or a documented exception, reviewed monthly
- Windows 10: support ended October 14, 2025
- Extended Security Updates: up to 3 years, version 22H2, **USD** (United States dollars) 61 per device in year 1, doubling yearly
- Kalmia bought nothing: ROAST-PC and the sales laptops — 374 days without updates tonight



Licences — the legal right to use software

- Copyright Act (Canada): a computer program is a literary work
- A licence is a permission from the copyright owner, under conditions (**EULA** (end-user licence agreement))
- More copies than the licence allows = legal and financial risk
- Cracked or pirated copies = a frequent malware carrier, and no updates
- Legal Notice v2.0, section 6.6: no cracked, patched or unlicensed software in any lab
- Open source is free of charge, not free of obligations (**SPDX** (Software Package Data Exchange) identifiers)



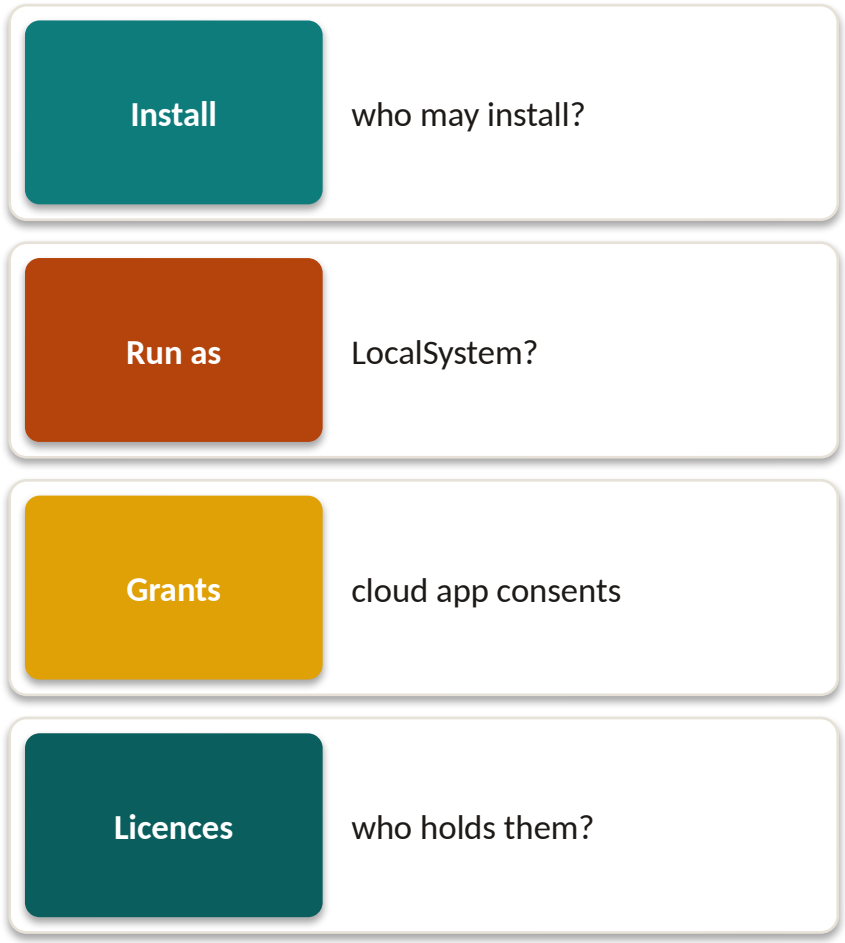
Licence metrics — what is counted

Metric	What is counted	At Kalmia
Per user	Distinct people, whatever the number of computers	Microsoft 365 (12), Sage 50 (2), Acrobat Pro (2)
Per device	Distinct computers where it is installed	RoastMaster Pro (1, ROAST-PC)
Concurrent	People using it at the same moment	None
Subscription / perpetual	Renewed every month or year, or bought once	Microsoft 365 and Sage 50: subscriptions
OEM (original equipment manufacturer)	Sold with the hardware, tied to that computer	Windows on the Dell computers
Freeware	Free of charge; its terms may forbid some uses	Chrome, Acrobat Reader
Open source	Free to use, study, change, share — under a licence	7-Zip (**LGPL** (GNU Lesser General Public License)), Firefox (MPL-2.0)

Compliance = installed or used ≤ bought, counted with the right metric — people for per-user, computers for per-device

Software and permissions — four questions

- Who may install? Admin rights on daily accounts → anyone installs anything
  - a program can also install itself in the user's profile, without admin approval
- With which rights does it run? A LocalSystem service has full control of the computer
- Which permissions does a cloud app request? “Accept” can grant mail, files, contacts
- Who holds each licence? A former employee's licence is waste — and an account that may still reach data
- Control: application allowlisting — only approved software runs (**CIS** (Center for Internet Security) 2.5)
  - on Windows: App Control for Business or AppLocker



Real-life example 2 — six computers against the licence register

Finding	Where	Rule
Unsupported operating system	ROAST-PC, SALES-LT1 — Windows 10 22H2, no **ESU** (Extended Security Updates), 374 days	**CIS** (Center for Internet Security) 2.2 — exception or upgrade
Unauthorized remote access as LocalSystem	ROAST-PC — RoastLink Remote 2.1.7 (service RoastLinkSvc)	**CIS** 2.3 · Lesson 1 finding
Unauthorized program in a user profile	PC-FIN-01 — **PDF** (Portable Document Format) Super Converter, LocalSystem updater	**CIS** 2.3 — remove
Unauthorized compression tool	PC-OPS-01, PC-MKT-01 — WinRAR 7.01	**CIS** 2.3 — approve or remove
Over-deployed licence	Adobe Acrobat Pro — 3 users, 2 per-user licences	Licence compliance
Compliant	Sage 50 (2/2), RoastMaster Pro (1/1), Microsoft 365 (5 seen / 12)	Keep the register current

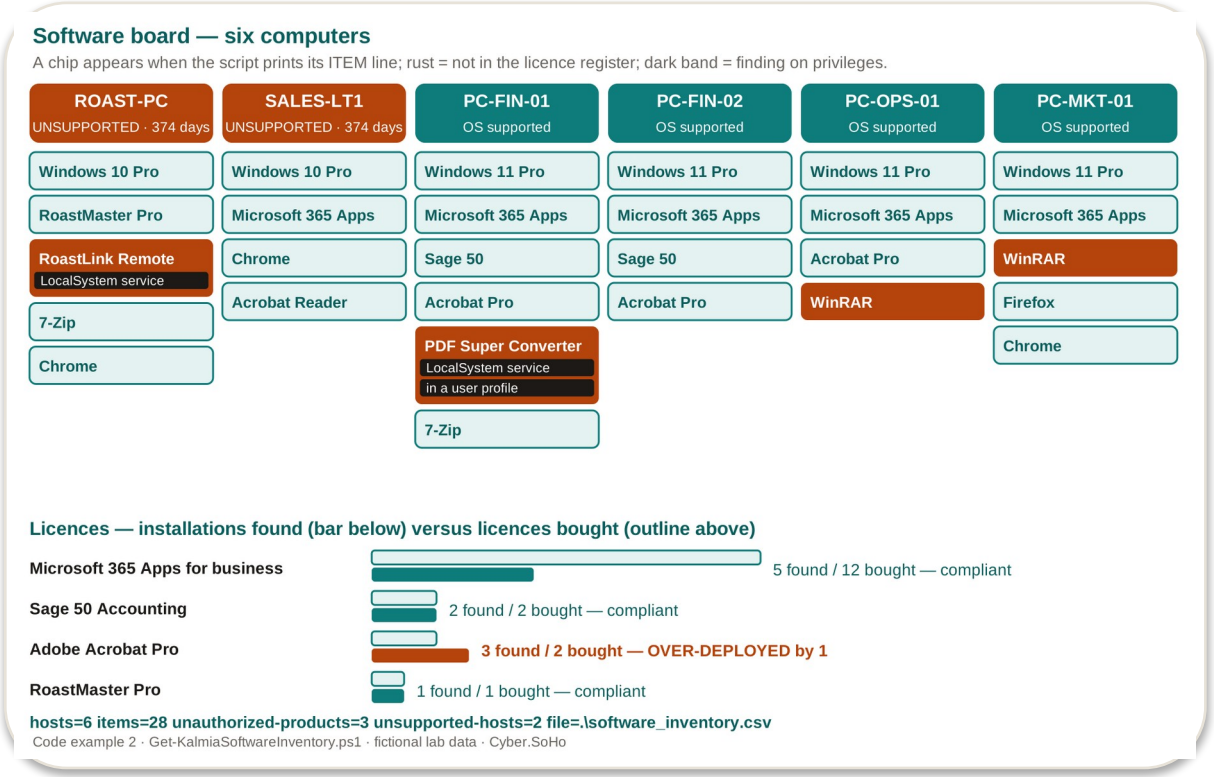
2 unsupported
Windows 10 without **ESU** — 374 days

3 unauthorized
RoastLink Remote, **PDF** Super Converter, WinRAR

1 over-deployed
Acrobat Pro: 3 users, 2 licences

Collecting the data — code example 2 (PowerShell)

- Real mode: three Uninstall registry keys (64-bit, 32-bit, current user), **CIM** (Common Information Model), Win32_Service
- Never Win32_Product: Windows Installer checks — and sometimes repairs — every package
- Lab mode: the same data from the exports of six computers
- Checks every item against the register: authorized, supported, licences per metric
- Flags LocalSystem services of unauthorized software and installs in a user profile
- Writes software_inventory.csv → Software sheet · Linux: dpkg-query -W, rpm -qa



Final state of the visualization in the code runner of the lecture module — Start, Pause, Step, Next output, Restart

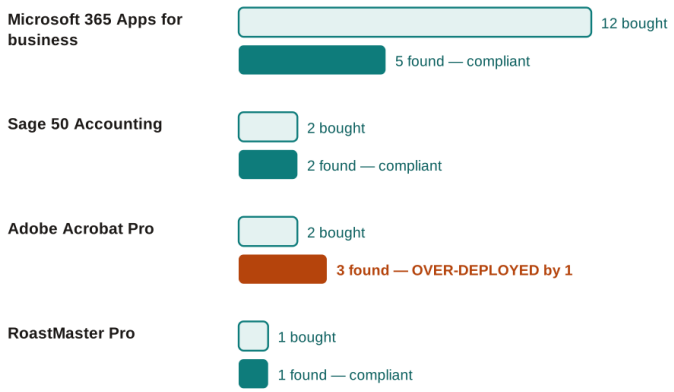
```
PS> .\Get-KalmiaSoftwareInventory.ps1 -InputFolder .\data2 -RegisterPath .\data2\licence_register.csv
```

Graph 8 — Licences used versus bought, and the support status of each computer

Graph 8 — Licences used versus licences bought, and the support status of each computer

From the run of code example 2 (Get-KalmiaSoftwareInventory.ps1) on six computers, October 23, 2026

A — Licences: users or devices found versus licences bought



Microsoft 365 is counted here on the six inventoried computers only; the real number of named users comes from the Microsoft 365 admin centre. A per-user licence counts people, a per-device licence counts machines (Lesson 2).

B — The six computers: operating system, support and software findings

ROAST-PC
Windows 10 Pro 22H2 · build 10.0.19045
UNSUPPORTED — no security updates
support ended 2025-10-14 (374 days ago)
5 items installed
not in the register: RoastLink Remote

SALES-LT1
Windows 10 Pro 22H2 · build 10.0.19045
UNSUPPORTED — no security updates
support ended 2025-10-14 (374 days ago)
4 items installed

PC-FIN-01
Windows 11 Pro 25H2 · build 10.0.26200
Supported
6 items installed
not in the register: PDF Super Converter
Adobe Acrobat Pro: licence over-deployed

PC-FIN-02
Windows 11 Pro 25H2 · build 10.0.26200
Supported
4 items installed
Adobe Acrobat Pro: licence over-deployed

PC-OPS-01
Windows 11 Pro 25H2 · build 10.0.26200
Supported
4 items installed
not in the register: WinRAR
Adobe Acrobat Pro: licence over-deployed

PC-MKT-01
Windows 11 Pro 25H2 · build 10.0.26200
Supported
5 items installed
not in the register: WinRAR

What the run found

- 6 computers · 28 installed items · 3 unauthorized products (RoastLink Remote, PDF Super Converter, WinRAR) · 2 unsupported computers (Windows 10) · 1 over-deployed licence (Adobe Acrobat Pro: 3 users, 2 licences)
- ROAST-PC: the service RoastLinkSvc of RoastLink Remote runs as LocalSystem — the most powerful account of Windows — and starts automatically
- PC-FIN-01: the service PDFSuperUpdater of PDF Super Converter runs as LocalSystem — the most powerful account of Windows — and starts automatically
- PC-FIN-01: PDF Super Converter was installed in Sophie Tremblay's user profile from a daily account with administrator rights — it never passed through IT approval (CIS Safeguards 2.3 and 2.5)

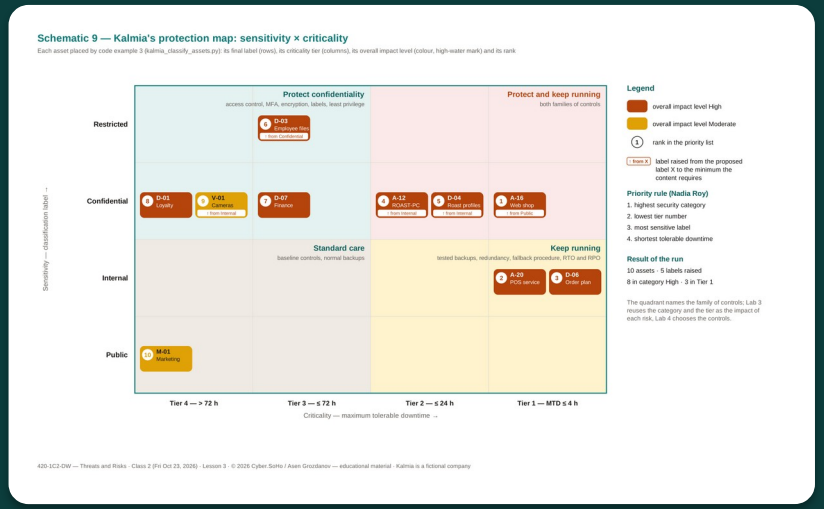
420-1C2-DW — Threats and Risks · Class 2 (Fri Oct 23, 2026) · Lesson 2 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material · Kalmia is a fictional company

3

Lesson 3 · 0:31 – 0:45

Asset classification, ownership and criticality

- Classification labels and their rules
- The security category and the high-water mark
- Owner, custodian, **RACI**
- Criticality: **MTD**, **RTO**, **RPO** and tiers
- The protection map and the priority list



Schematic 9 — Kalmia's protection map: sensitivity × criticality

Abbreviations: **MTD** (maximum tolerable downtime) · **RACI** (Responsible, Accountable, Consulted, Informed) · **RPO** (recovery point objective) · **RTO** (recovery time objective)

From a list to priorities

- Kalmia cannot protect forty assets equally: one half-time **IT** (information technology) coordinator, about $8,000 this year
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 · ID.AM-05: assets are prioritized by classification, criticality, resources and mission impact
- **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001:2022, Annex A:
  - 5.9 inventory of information and other associated assets, with their owners
  - 5.12 classification of information — confidentiality, integrity, availability
  - 5.13 labelling of information
- Tonight: the method · tomorrow: the data and services critical to operations

ID.AM-05

prioritize assets

A.5.9

inventory with owners

A.5.12

classification

A.5.13

labelling

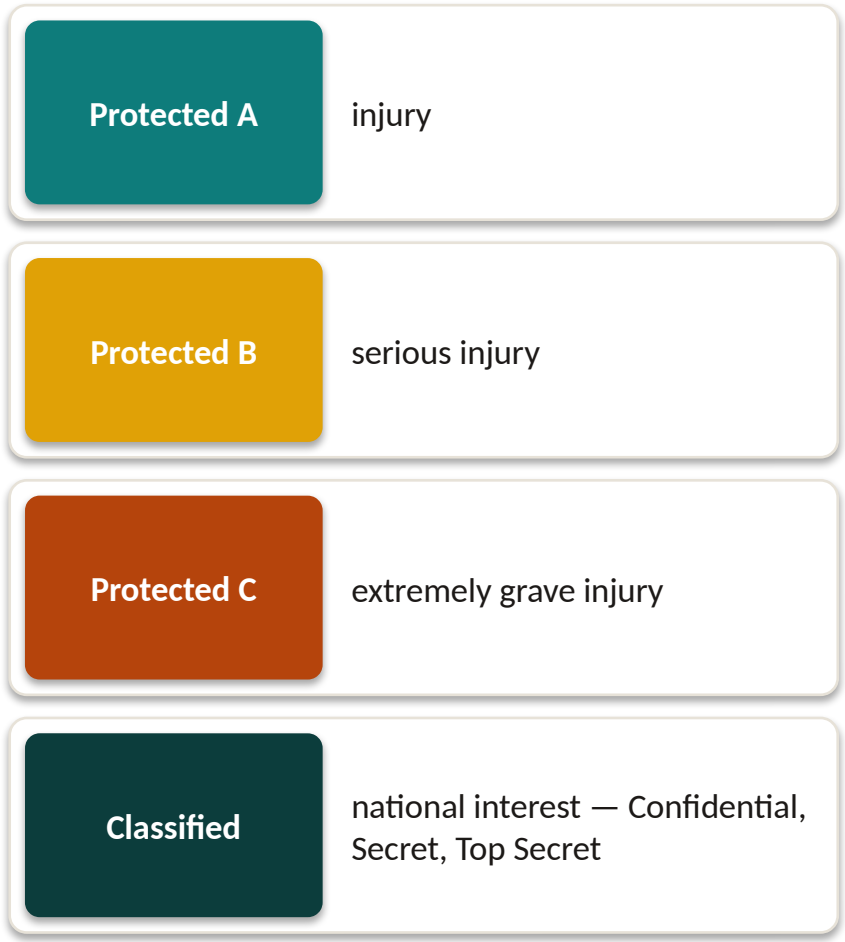
Kalmia's four classification labels

Label	Harm if disclosed	Kalmia examples	Handling (summary)
Public	None — approved for publication	Menu, product pages, brochures	No restriction once approved
Internal	Minor inconvenience; staff only	Schedules, procedures, daily order plan	Staff accounts only
Confidential	Significant harm to Kalmia, customers or staff	Personal information, contracts, finance, roast profiles	Named groups; encrypted outside; locked storage
Restricted	Severe harm, legal duties, hard to repair	**SIN** (Social Insurance Number) and bank details of employees, admin passwords	Named people; **MFA** (multi-factor authentication); quarterly access review

The label follows the information; a system takes the highest label of what it holds

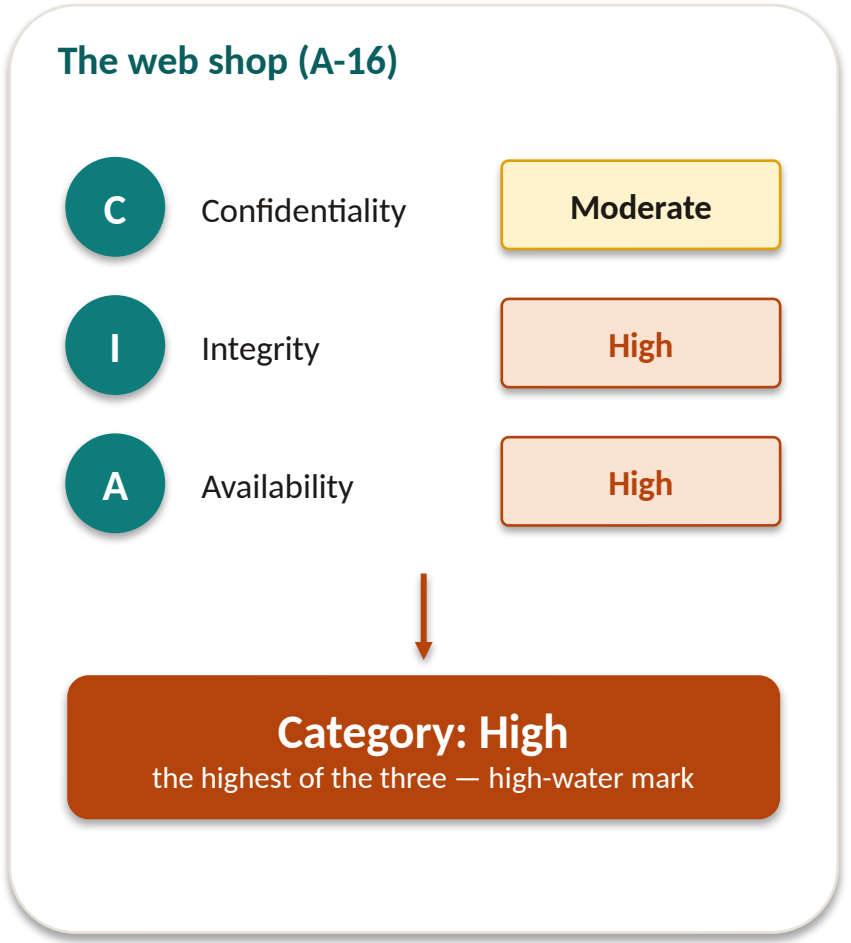
Classification rules — and the Government of Canada scheme

- The label follows the information: every copy, every system, every report
- A system takes the highest label of what it holds
  - the web shop shows public pages but stores 2,300 subscribers → Confidential
- Québec, P-39.1 s. 10: security measures reasonable for the sensitivity, purposes, quantity, distribution and medium
- Government of Canada — Protected A, B, C: injury, serious injury, extremely grave injury
- Classified — Confidential, Secret, Top Secret: injury to the national interest
- A private company chooses its own labels: defined, approved, applied



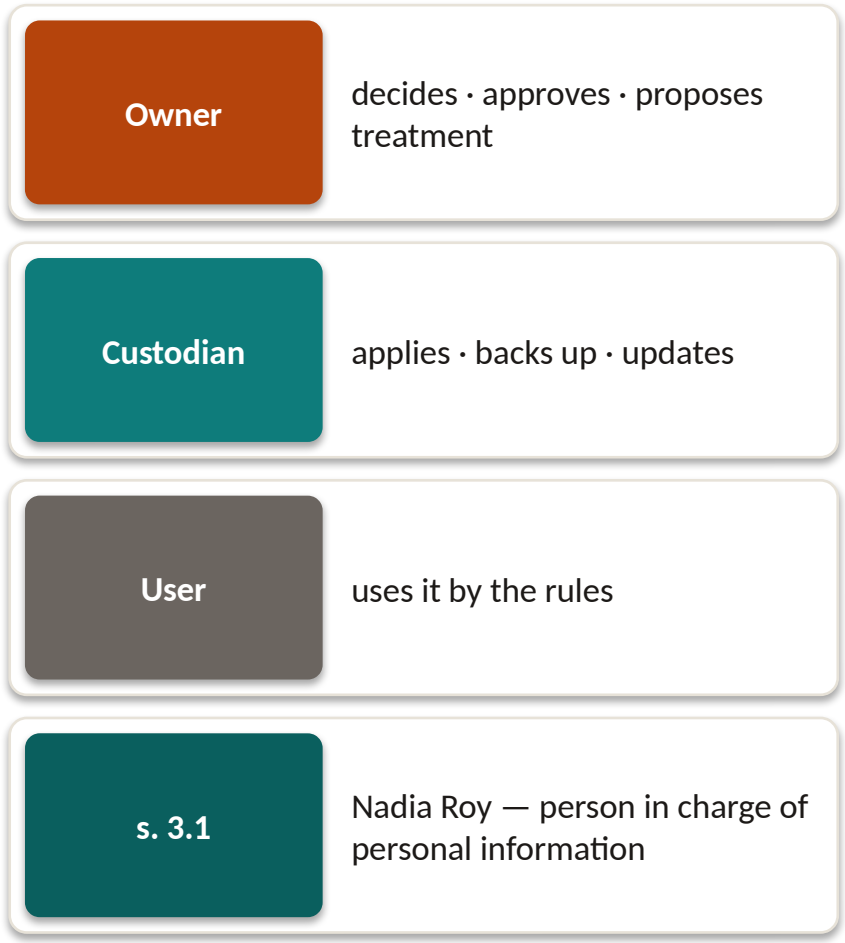
Security categorization — the FIPS 199 recap

- Impact level of a loss of C, I or A:
  - Low: limited adverse effect · Moderate: serious · High: severe or catastrophic
- Security category = { (C, impact), (I, impact), (A, impact) }
- Overall impact level = the highest of the three: the high-water mark (**FIPS** (Federal Information Processing Standard) 200)
- Web shop: { (C, Moderate), (I, High), (A, High) } → High
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-60 applies it to types of information and to the systems that hold them



Ownership — owner, custodian, user

- Asset owner: the manager accountable — decides the label, approves access, proposes how risks are treated
- Custodian: looks after the asset day to day — permissions, backups, updates
- Users: use it according to the rules
- Employee files: Sophie Tremblay owns them; Lucas Martin, the payroll provider and InfoNord **MSP** (managed service provider) are custodians
- For information, the owner is a business role — **IT** (information technology) is usually the custodian
- Québec, P-39.1 s. 3.1: the enterprise is responsible; its highest authority is the person in charge unless delegated in writing
  - at Kalmia: Nadia Roy — title and contact information published on the website



RACI — who does what for the HR share of NAS-01

Task	Sophie Tremblay (owner)	Lucas Martin (custodian)	InfoNord MSP (managed service provider)	Nadia Roy
Decide the label (Restricted)	A / R	C	—	I
Approve who may read the share	A	R	—	I
Set the folder permissions and MFA (multi-factor authentication)	C	R / A	C	—
Run and test the backups	I	A	R	—
Accept the residual risk	R	C	—	A

R — Responsible
does the work

A — Accountable
answers for the result — one person

C — Consulted
gives advice before

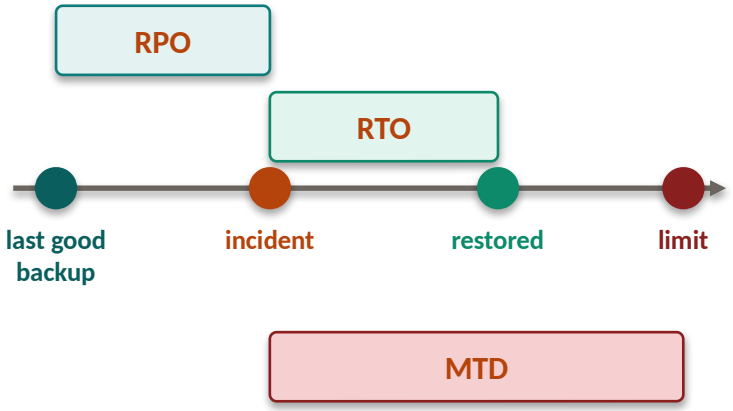
I — Informed
is told after

Abbreviations: **HR** (human resources) · **RACI** (Responsible, Accountable, Consulted, Informed)

Criticality — the business impact analysis

- Criticality: how much operations depend on an asset, whatever its sensitivity
- Business impact analysis (**BIA**): how long can the business survive without it?
- Maximum tolerable downtime (**MTD**): the longest interruption the business can accept
- Recovery time objective (**RTO**): the time to restore — never longer than the **MTD**
- Recovery point objective (**RPO**): the maximum data loss, measured in time
  - the **RPO** fixes how often the backups must run

One incident on a time line



RPO — the data you may lose (back to the last good backup)
RTO — the time to restore; never longer than the **MTD**
MTD — the longest interruption the business accepts
Kalmia: **POS** service, **MTD** 2 h → Tier 1

Abbreviations: **POS** (point of sale)

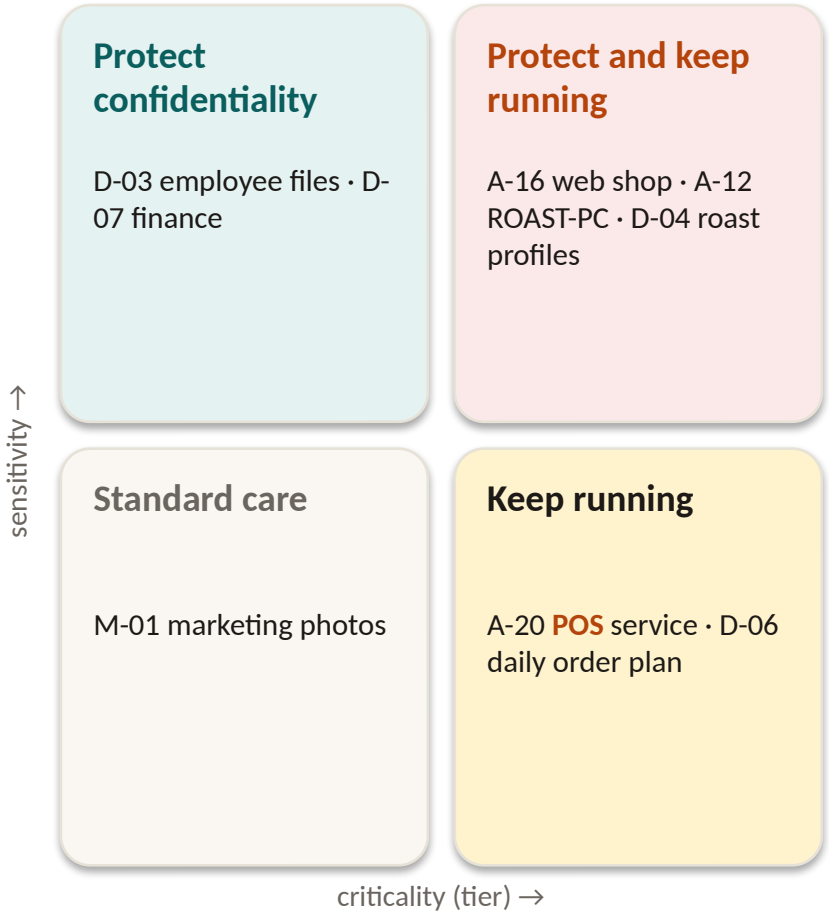
Criticality tiers at Kalmia

Tier	Maximum tolerable downtime	Kalmia examples
Tier 1 — critical	4 hours or less	**POS** (point of sale) service (2 h), daily order plan (4 h), web shop in Nov–Dec (4 h)
Tier 2 — high	more than 4 h, up to 24 h	ROAST-PC (8 h), roast profiles (24 h)
Tier 3 — medium	more than 24 h, up to 72 h	Financial records, employee files (72 h)
Tier 4 — low	more than 72 h	Loyalty records, camera recordings, marketing photos

Criticality changes with the season: the web shop is Tier 2 in July and Tier 1 in November and December
The inventory records the most demanding season

Two axes — protect it, keep it running, or both

- Classification answers: how sensitive is it?
- Criticality answers: how much do we depend on it?
- Marketing photos: Public, Tier 4 → standard care
- Daily order plan: Internal, Tier 1 → keep it running (backups, fast recovery)
- Employee files: Restricted, Tier 3 → protect confidentiality (access control)
- Priority rule (Nadia Roy): category → tier → label → shortest **MTD** (maximum tolerable downtime)



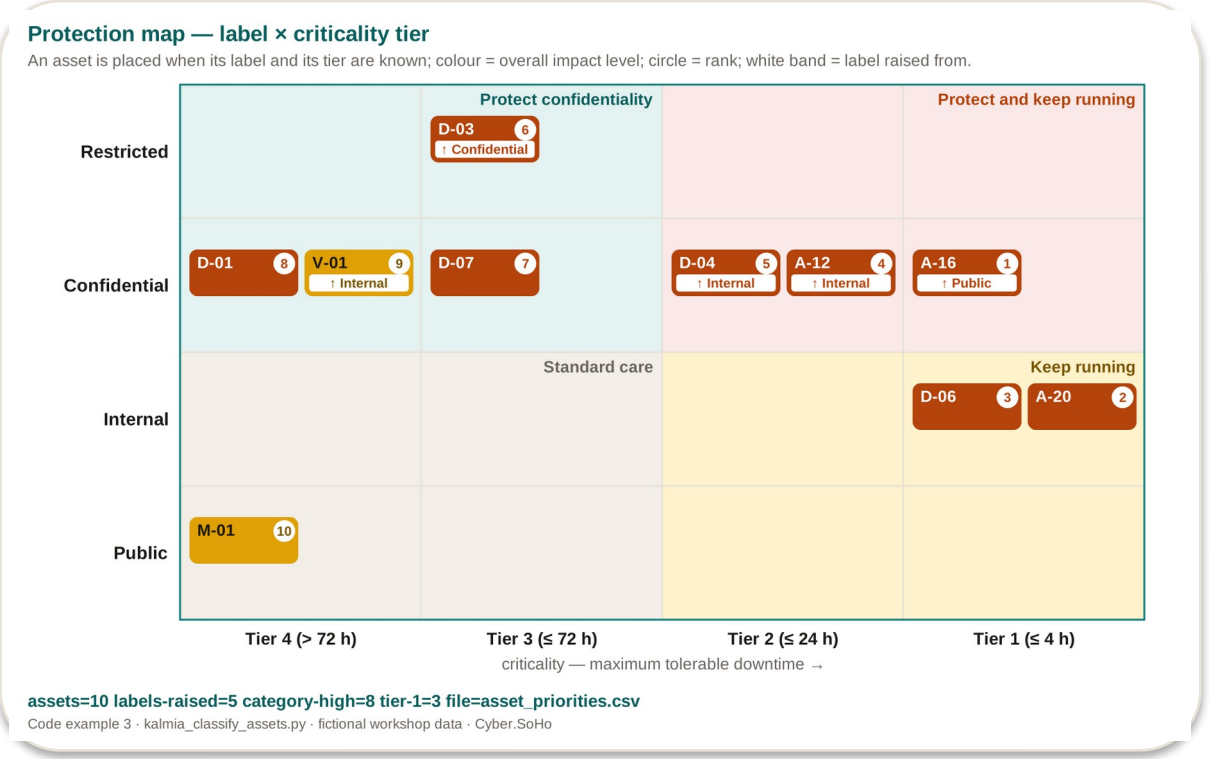
Abbreviations: **POS** (point of sale)

Real-life example 3 — ten assets, one priority list

#	Asset	Final label	Category	Tier	Quadrant
1	A-16 Web shop	Confidential ↑	High	1	Protect and keep running
2	A-20 POS (point of sale) service	Internal	High	1	Keep running
3	D-06 Daily order plan	Internal	High	1	Keep running
4	A-12 ROAST-PC	Confidential ↑	High	2	Protect and keep running
5	D-04 Roast profiles	Confidential ↑	High	2	Protect and keep running
6	D-03 Employee files	Restricted ↑	High	3	Protect confidentiality
7	D-07 Financial records	Confidential	High	3	Protect confidentiality
8	D-01 Loyalty records	Confidential	High	4	Protect confidentiality
9	V-01 Camera recordings	Confidential ↑	Moderate	4	Protect confidentiality
10	M-01 Marketing photos	Public	Moderate	4	Standard care

Code example 3 — kalmia_classify_assets.py (Python)

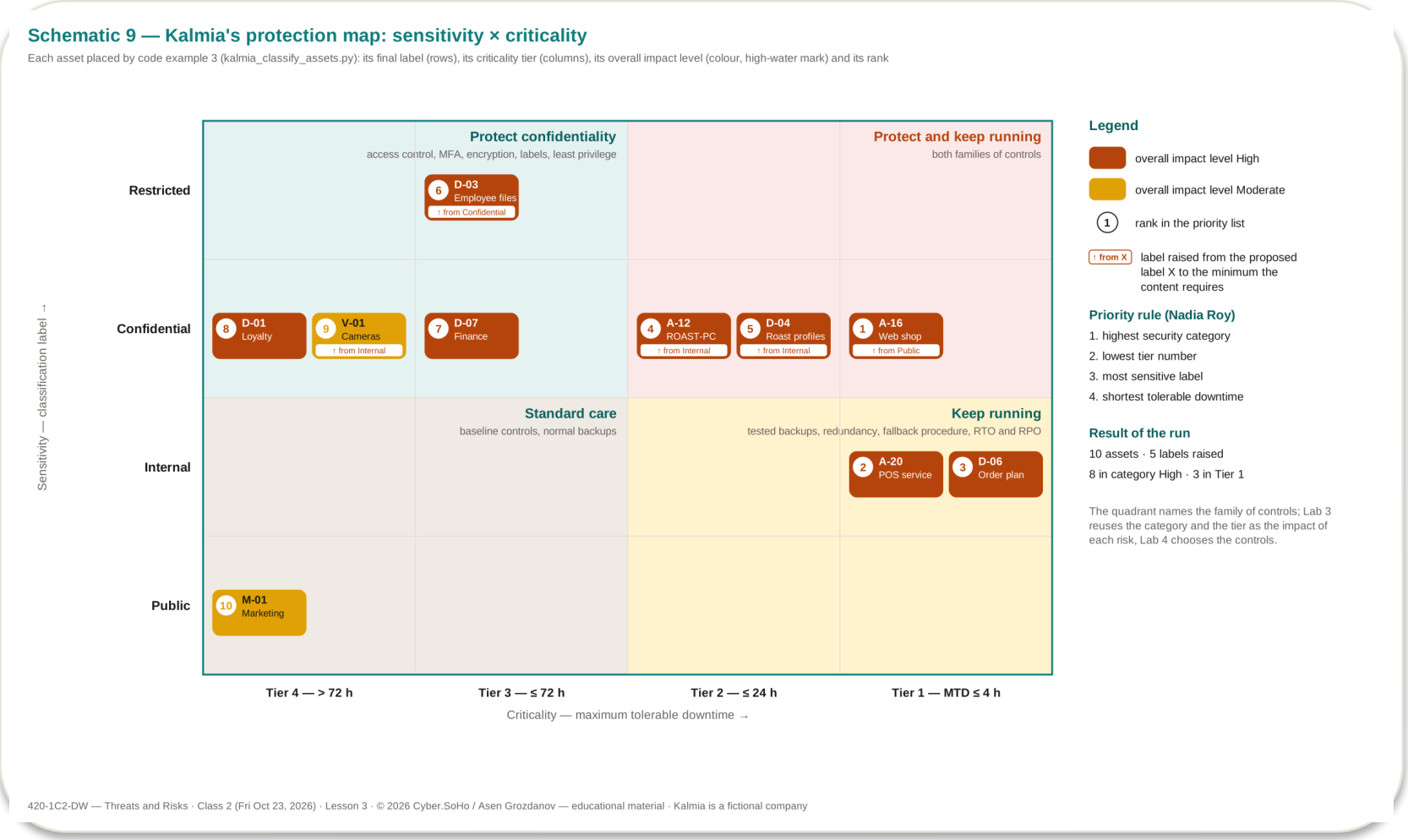
- Refuses any rating that is not Low, Moderate or High
- Raises a label below the minimum its content requires
- Computes the category with max() — the high-water mark
- Converts the **MTD** (maximum tolerable downtime) into a tier (4 h, 24 h, 72 h)
- Ranks with one sort key: category, tier, label, **MTD**
- Writes asset_priorities.csv → Classification sheet; Lab 3 impact column



Final state of the visualization in the code runner of the lecture module — Start, Pause, Step, Next output, Restart

```
$ python kalmia_classify_assets.py asset_ratings.csv
```

Schematic 9 — Kalmia's protection map: sensitivity × criticality

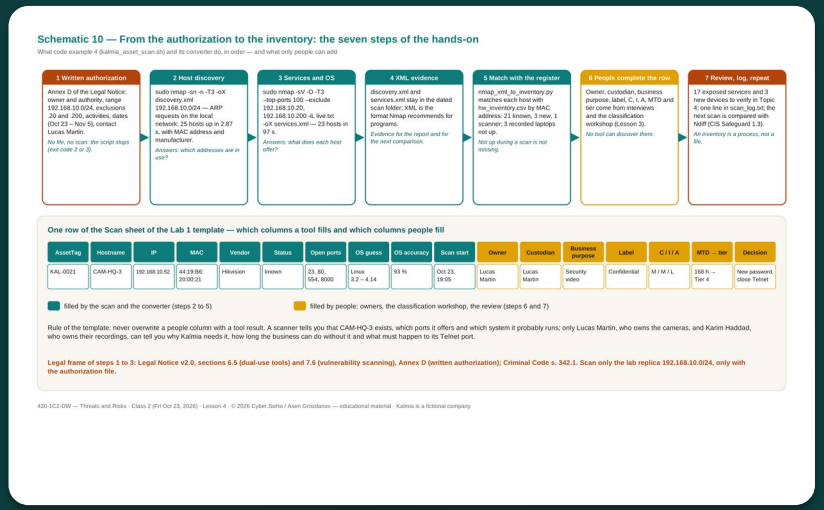


4

Lesson 4 · 0:45 – 1:00

Hands-on: building an asset inventory with a template and a network scanner (Nmap)

- The Lab 1 template
- Authorization before the first packet
- Host discovery, then ports, services and OS
- From XML to the template
- Review, record, repeat — and the limits

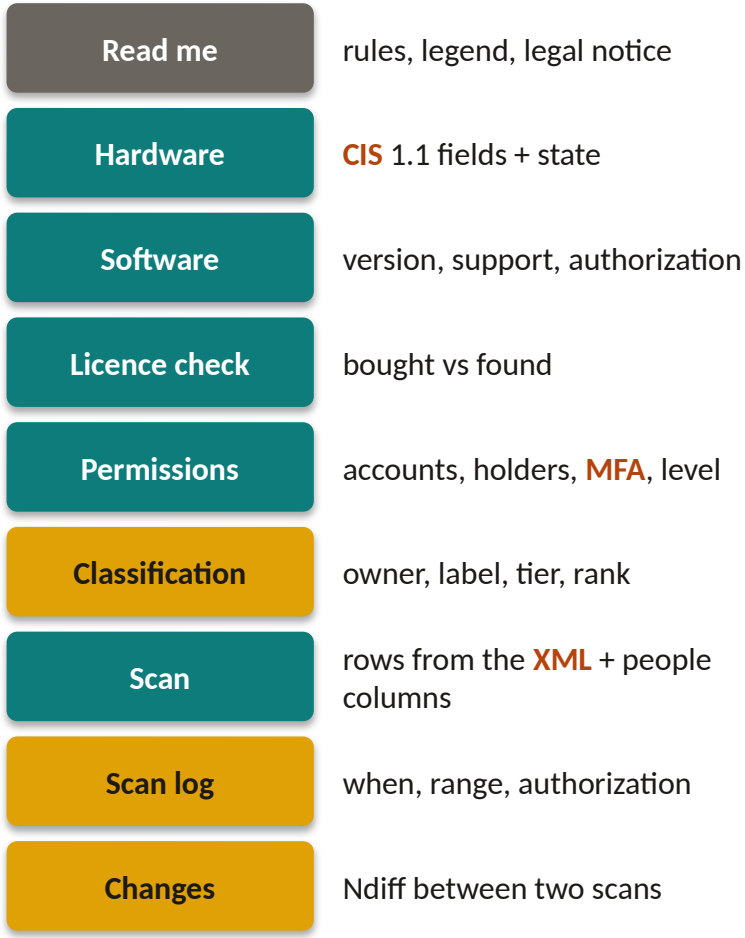


Schematic 10 — From the authorization to the inventory: the seven steps of the hands-on

Abbreviations: **Nmap** (Network Mapper) · **OS** (operating system) · **XML** (Extensible Markup Language)

The Lab 1 template — one inventory, one identifier

- One workbook, one line per asset, the same identifier everywhere
- Sheets: Read me · Hardware · Software · Licence check · Permissions · Classification · Scan · Scan log · Changes
- Drop-down lists keep one vocabulary for everyone
- Teal columns: a tool can fill them (export, script, scan)
- Amber columns: only people can fill them (owner, label, tier, decision)
- A scanner tells you a device exists — never who owns it or how critical it is



Abbreviations: **CIS** (Center for Internet Security) · **MFA** (multi-factor authentication) · **XML** (Extensible Markup Language)

Nmap in one slide

- **Nmap** (Network Mapper): free and open source, first published in 1997 by Gordon Lyon
- Runs on Linux, Windows and macOS · Zenmap = graphical interface · Ndiff = compares two scans
- An active scanner: sends probes, interprets the answers (**CIS** (Center for Internet Security) Safeguard 1.3)
- A dual-use tool (Legal Notice 6.5): lawful and widely used —
  - possibly a criminal offence when pointed at a system you are not authorized to scan
- Download it only from nmap.org

1997

first release — Gordon Lyon

Free

open source · nmap.org

Zenmap

graphical interface

Ndiff

compares two scans

Authorization before the first packet

- Legal Notice 7.6: “A scan is an intrusive act, not an observation”
- Logged, can trigger alerts, can crash a fragile device, looks like an attack
- Criminal Code s. 342.1: using a computer system without authorization can be an offence
- **Nmap** (Network Mapper)'s own book: written authorization first, a legitimate reason, the tightest scope
- Annex D: owner and authority, range, exclusions, activities, dates, contact
- Tonight: 192.168.10.0/24 · excluded .20 (ROAST-PC, **OT** (operational technology)) and .200 (the scanner)

Annex D — written authorization (lab replica)

Owner	Nadia Roy, President (fictional)
Scope	192.168.10.0/24
Exclude	192.168.10.20 · 192.168.10.200
Permitted	-sn · -sV · -O
Not permitted	scripts, brute force, DoS
Valid	Oct 23 – Nov 5, 2026
Contact	Lucas Martin, ext. 204

Step 1 — host discovery

- -sn: which addresses are up? — no port scan
- Default probes: **ICMP** (Internet Control Message Protocol) echo, **TCP** (Transmission Control Protocol) **SYN** (synchronize, the TCP flag that opens a connection) to 443, **TCP ACK** (acknowledgement, the TCP flag that confirms received data) to 80, **ICMP** timestamp
- On a local Ethernet network: **ARP** (Address Resolution Protocol) requests — faster, and they reveal the **MAC** (Media Access Control) address
- sudo: only a privileged **Nmap** (Network Mapper) sends **ARP** and records **MAC** addresses
- -n: no **DNS** (Domain Name System) lookups · -oX: **XML** (Extensible Markup Language) output
- /24 (**CIDR** (Classless Inter-Domain Routing)): 24 network bits → 256 addresses · 25 answered (scanner included)

What Nmap sends to each address

ICMP echo	the classic ping
TCP SYN → 443	half-open connection
TCP ACK → 80	crosses some filters
ICMP timestamp	another **ICMP** type

On a local Ethernet network: ARP
faster, more reliable — and it gives the **MAC** address (with sudo)

25 of 256 addresses answered

```
$ sudo nmap -sn -n -T3 -oX discovery.xml 192.168.10.0/24
```

Step 2 — ports, services, operating systems

- A port (0–65535, per **TCP** (Transmission Control Protocol) and **UDP** (User Datagram Protocol)) identifies one service on a host
- 22 **SSH** (Secure Shell) · 23 Telnet · 80 **HTTP** (Hypertext Transfer Protocol) · 443 **HTTPS** (Hypertext Transfer Protocol Secure) · 445 **SMB** (Server Message Block) · 554 **RTSP** (Real Time Streaming Protocol) · 3389 **RDP** (Remote Desktop Protocol)
- Six states: open · closed · filtered · unfiltered · open|filtered · closed|filtered
- -sV service and version · -O **OS** (operating system) guess with accuracy (administrator rights)
- --top-ports 100 (default 1,000) · -iL targets from a file · --exclude never touch

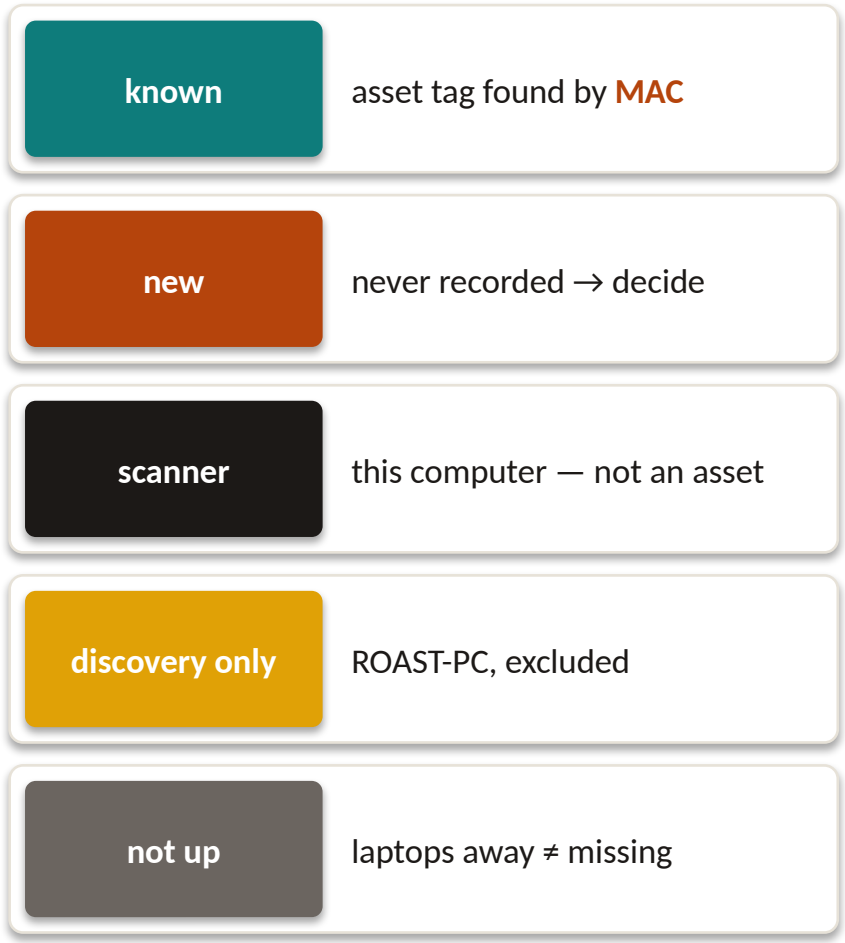
open	a service answers — record it
closed	reachable, no service
filtered	a firewall blocks the probes
open|filtered	**Nmap** cannot tell (**UDP**)

```
$ sudo nmap -sV -O -T3 --top-ports 100 --exclude 192.168.10.20,192.168.10.200 -iL live.txt -oX services.xml
```

Abbreviations: **Nmap** (Network Mapper)

Step 3 — from XML to the template

- Output formats: normal, **XML** (Extensible Markup Language), grepable — or all three (-oA)
- **XML**: the format **Nmap** (Network Mapper) recommends for programs
- The converter matches each host with the register by **MAC** (Media Access Control) address
- Status: known (asset tag) · new (never recorded) · scanner (the scanning computer)
- Hosts excluded from the service scan: “discovery only” (ROAST-PC)
- Not up during a scan ≠ missing — laptops travel (Lesson 1 waits 30 days)



Step 4 — review, record, repeat · the limits of a scan

- Every open service is attack surface — warning signs for Topic 4:
  - Telnet on the switch and two cameras · web administration without encryption
  - **SMB** (Server Message Block) open on two workstations, **RDP** (Remote Desktop Protocol) on one · three new devices
- Record: scan log (when, range, authorization) · keep the **XML** (Extensible Markup Language) files
- Repeat: **CIS** (Center for Internet Security) 1.3 — daily for IG2 and IG3 · Ndiff shows what changed
- Limits: up and reachable only · a firewall hides a computer · cafés and cloud out of range
- An **OS** (operating system) guess is a probability — the scan is one source, never the inventory

17
exposed services

3
new devices

6
computers showing only filtered ports

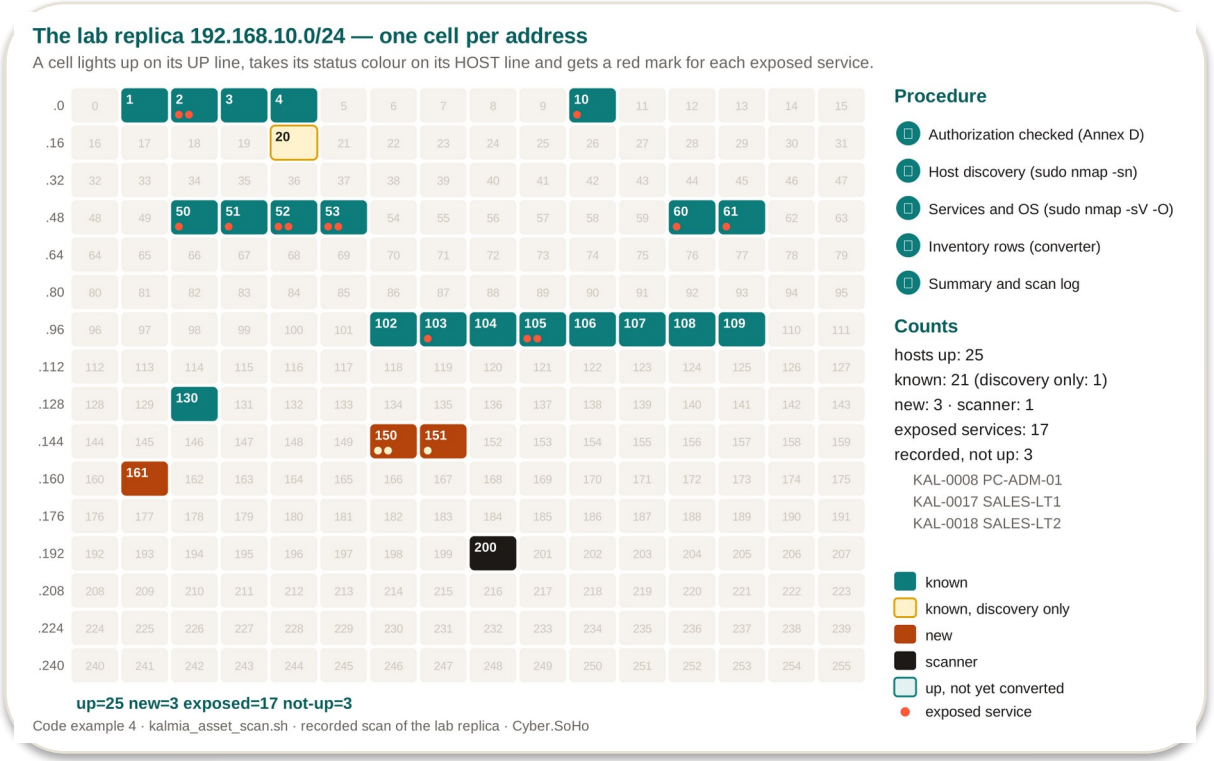
Daily
CIS 1.3 · IG2 and IG3

Real-life example 4 — the first scan of the lab replica

Host and address	Status	Open ports (top 100)	Note for Topic 4
SW-HQ (.2)	known	23 telnet, 80 http	Clear-text administration
NAS-01 (.10)	known	22, 139/445 smb, 5000 http	Web administration without encryption
ROAST-PC (.20)	discovery only	not scanned (excluded)	**OT** (operational technology) — handled by agreement
CAM-HQ-3, -4 (.52, .53)	known	23 telnet, 80, 554, 8000	Telnet + factory password
PRN-HQ-1, -2 (.60, .61)	known	80, 515, 631, 9100	Admin page without password
PC-FIN-01, PC-IT-01	known	445; 445 + 3389 rdp	File sharing, remote desktop
6 office computers	known	none (all filtered)	Firewall on — nothing to see
THERMO-HQ (.130)	known	none (all closed)	Reachable, no service listening
.150 / .151 / .161	new	22 + 80 / 53 + 80 / none	Vendor logger, extender, phone
3 laptops	not up	—	Away or off — not proof of loss

Code example 4 — kalmia_asset_scan.sh (Bash)

- Refuses to scan without a scope and an authorization file
- Checks the scope, the end date and the exclusions written in the file
- Runs discovery, extracts the live hosts, then services and **OS** (operating system)
- Calls nmap_xml_to_inventory.py → scan_inventory.csv
- Appends one line to scan_log.txt — the evidence of the scan
- Replay mode (-r) uses the recorded scan: no lab needed to study it



Final state of the visualization in the code runner of the lecture module — Start, Pause, Step, Next output, Restart

```
$ ./kalmia_asset_scan.sh -s 192.168.10.0/24 -a authorization_annexD_lab.txt -r recorded
```

Schematic 10 — From the authorization to the inventory

Schematic 10 — From the authorization to the inventory: the seven steps of the hands-on

What code example 4 (kalmia_asset_scan.sh) and its converter do, in order — and what only people can add

1 Written authorization

Annex D of the Legal Notice: owner and authority, range 192.168.10.0/24, exclusions .20 and .200, activities, dates (Oct 23 – Nov 5), contact Lucas Martin.

No file, no scan: the script stops (exit code 2 or 3).

2 Host discovery

sudo nmap -sn -n -T3 -oX discovery.xml 192.168.10.0/24 — ARP requests on the local network: 25 hosts up in 2.87 s, with MAC address and manufacturer.

Answers: which addresses are in use?

3 Services and OS

sudo nmap -sV -O -T3 --top-ports 100 --exclude 192.168.10.20, 192.168.10.200 -iL live.txt -oX services.xml — 23 hosts in 97 s.

Answers: what does each host offer?

4 XML evidence

discovery.xml and services.xml stay in the dated scan folder; XML is the format Nmap recommends for programs.

Evidence for the report and for the next comparison.

5 Match with the register

nmap_xml_to_inventory.py matches each host with hw_inventory.csv by MAC address: 21 known, 3 new, 1 scanner; 3 recorded laptops not up.

Not up during a scan is not missing.

6 People complete the row

Owner, custodian, business purpose, label, C, I, A, MTD and tier come from interviews and the classification workshop (Lesson 3).

No tool can discover them.

7 Review, log, repeat

17 exposed services and 3 new devices to verify in Topic 4; one line in scan_log.txt; the next scan is compared with Ndiff (CIS Safeguard 1.3).

An inventory is a process, not a file.

One row of the Scan sheet of the Lab 1 template — which columns a tool fills and which columns people fill

AssetTag	Hostname	IP	MAC	Vendor	Status	Open ports	OS guess	OS accuracy	Scan start	Owner	Custodian	Business purpose	Label	C / I / A	MTD → tier	Decision
KAL-0021	CAM-HQ-3	192.168.10.52	44:19:B6: 20:00:21	Hikvision	known	23, 80, 554, 8000	Linux 3.2 – 4.14	93 %	Oct 23, 19:05	Lucas Martin	Lucas Martin	Security video	Confidential	M / M / L	168 h → Tier 4	New password, close Telnet

filled by the scan and the converter (steps 2 to 5)

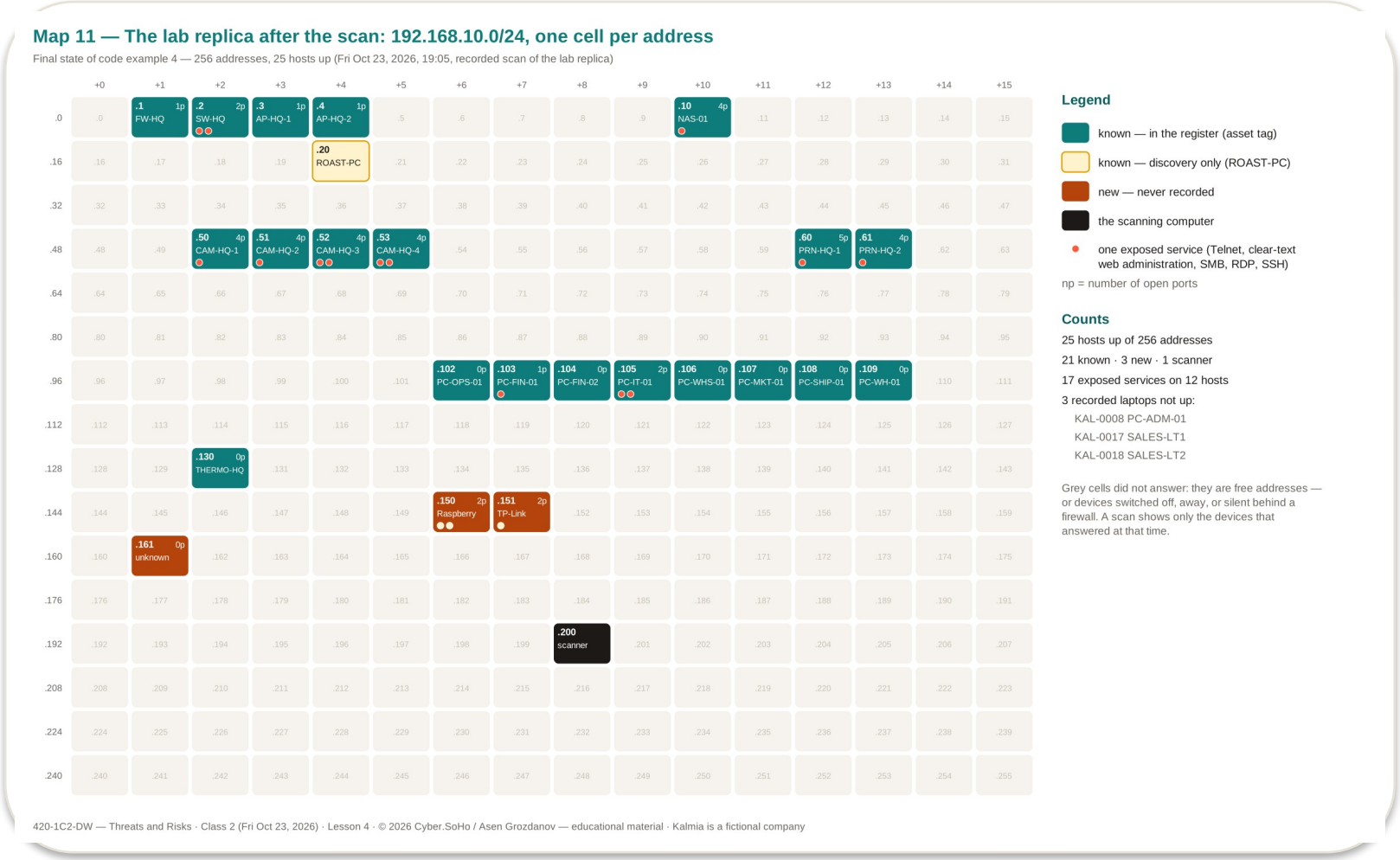
filled by people: owners, the classification workshop, the review (steps 6 and 7)

Rule of the template: never overwrite a people column with a tool result. A scanner tells you that CAM-HQ-3 exists, which ports it offers and which system it probably runs; only Lucas Martin, who owns the cameras, and Karim Haddad, who owns their recordings, can tell you why Kalmia needs it, how long the business can do without it and what must happen to its Telnet port.

Legal frame of steps 1 to 3: Legal Notice v2.0, sections 6.5 (dual-use tools) and 7.6 (vulnerability scanning), Annex D (written authorization); Criminal Code s. 342.1. Scan only the lab replica 192.168.10.0/24, only with the authorization file.

420-1C2-DW — Threats and Risks · Class 2 (Fri Oct 23, 2026) · Lesson 4 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material · Kalmia is a fictional company

Map 11 — The lab replica after the scan: 192.168.10.0/24



Videos for tonight (1/2) — Lessons 1 and 2

Lesson 1 — **Asset Management — CompTIA A+ 220-1202 — 4.1**

Professor Messer · 4 min 51 s — ▶️ Watch on YouTube

Lesson 1 — **Asset Management — CompTIA Security+ SY0-701 — 4.2**

Professor Messer · 8 min 37 s — ▶️ Watch on YouTube

Lesson 1 — **Data Destruction — CompTIA A+ 220-1202 — 2.9**

Professor Messer · 6 min 04 s — ▶️ Watch on YouTube

Lesson 2 — **Privacy, Licensing, and Policies — CompTIA A+ 220-1202 — 4.6**

Professor Messer · 10 min 54 s — ▶️ Watch on YouTube

Lesson 2 — **Security Vulnerabilities — CompTIA A+ 220-1202 — 2.5**

Professor Messer · 8 min 47 s — ▶️ Watch on YouTube

Videos for tonight (2/2) — Lessons 3 and 4

Lesson 3 — **Data Types and Classifications — CompTIA Security+ SY0-701 — 3.3**

Professor Messer · 5 min 54 s — ▶️ Watch on YouTube

Lesson 3 — **Data Roles and Responsibilities — CompTIA Security+ SY0-701 — 5.1**

Professor Messer · 2 min 27 s — ▶️ Watch on YouTube

Lesson 3 — **Business Impact Analysis — CompTIA Security+ SY0-701 — 5.2**

Professor Messer · 2 min 55 s — ▶️ Watch on YouTube

Lesson 4 — **Software Tools — CompTIA Network+ N10-009 — 5.5**

Professor Messer · 7 min 29 s — ▶️ Watch on YouTube

Lesson 4 — **Network Solutions — CompTIA Network+ N10-009 — 3.2**

Professor Messer · 6 min 57 s — ▶️ Watch on YouTube

Lesson 4 — **IPv4 Subnet Masks — CompTIA Network+ N10-009 — 1.7**

Professor Messer · 9 min 00 s — ▶️ Watch on YouTube

Abbreviations: **IPv4** (Internet Protocol version 4)

Hours 2–3 and Lab 1 — what the template must contain

- Tonight, Hours 2–3: the template, the four scripts, the two **Nmap** (Network Mapper) commands on the lab replica
- Hardware — **CIS** (Center for Internet Security) 1.1 fields, reconciliation state, last seen, next action
- Software and Licence check — version, support end, authorization, metric, service account
- Permissions — accounts, holders, **MFA** (multi-factor authentication), end dates, finding level
- Classification — owner, custodian, label, C-I-A, category, **MTD** (maximum tolerable downtime), tier, quadrant
- Scan, Scan log, Changes — rows from the **XML** (Extensible Markup Language), the evidence, the differences (Ndiff)
- Lab 1: starts Saturday (Class 3), due Thursday, November 5 — 5%
- Integrative Project: FORMATIVE — not graded

5%

Lab 1 — due Thursday, November 5

9

sheets to fill or read, plus the Lists

Sat

instructions and rubric — Class 3

0%

Integrative Project — FORMATIVE

Thank you — questions?

Next: Class 3 — Saturday, October 24, 2026, 2–6 pm, online
Topic 2 (Part 2) — data and services, network diagrams, permissions map · Lab 1 starts

Quiz 1 (Topics 1 and 2, 5%) — online, Saturday, October 24

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !
ALL Rights Reserverd